

위협 평가





학습내용

- 위험 분석 개요
- 위험 분석



학습목표

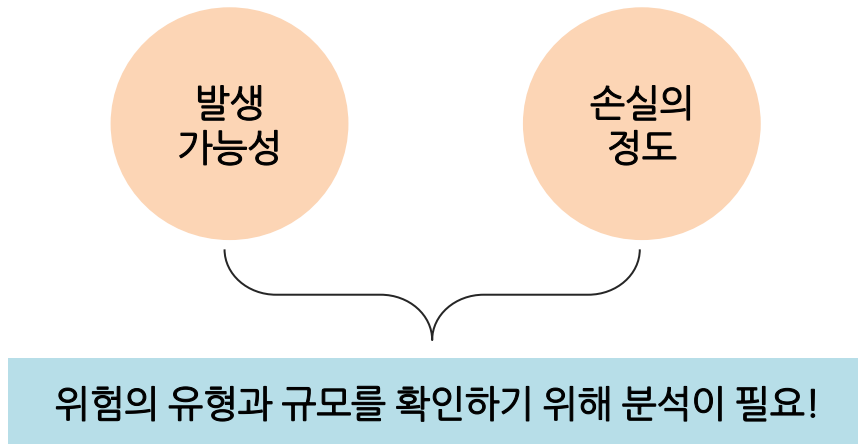
- 위험 분석에 대한 개념과 절차에 대해 설명할 수 있다.
- 위험 분석의 위험 평가를 수행할 수 있다.



위험 분석 개요

1. 위험의 정의

- 위험이란 원하지 않은 사건이 발생하여 손실 또는 부정적인 영향을 미칠 가능성을 말함
- 위험의 유형과 규모를 확인하기 위해서는 위험에 관련된 모든 요소들 즉 발생 가능성과 그들이 어떻게 위험의 규모에 영향을 미치는지 손실의 정도를 분석해야 함



🔑 위험 분석 개요

1. 위험의 정의

- 위험의 계산은 발생 가능성과 손실의 정도 혹은 자산, 위협, 취약점의 계산을 통해 위험의 정도를 측정할 수 있음
- 발생 가능성은 위협과 취약점으로 나타낼 수 있음
- 위협은 정보 및 유형 자산에 피해를 주어 시스템이나 조직에 손실을 유발할 수 있는 잠재적인 요소를 의미
- 취약점은 위협에 의해 손실을 입을 수 있는 자산의 약점을 의미
- 손실의 정도는 자산중요도로 표현이 가능하며, 이는 자산가치의 우선 순위를 판단하기 위한 기준으로 사용됨



발생 가능성	• 위협과 취약점으로 나타낼 수 있음
위협	• 정보 및 유형 자산에 피해를 주어 시스템이나 조직에 손실을 유발할 수 있는 잠재적인 요소를 의미
취약점	• 위협에 의해 손실을 입을 수 있는 자산의 약점을 의미
손실의 정도	• 자산중요도로 표현 가능 • 자산가치의 우선순위를 판단하기 위한 기준으로 사용

2. 위험의 구성요소

1) 자산, 위협, 취약점의 관계

- 위험을 구성하는 요소로는 자산, 위협, 취약점이 있음
- 위험이 현실화되어 나타났을 경우 손실의 정도는 자산의 중요도에 의해서 판단할 수 있으므로 손실의 정도를 예측하여 각 자산별 보호 우선순위를 정리할 필요가 있음

- [예] ✓ 돈이 많이 들어있는 금고를 집에 보관하고 있을 경우 도둑들에 의해 도난당할 가능성이 있으며, 위협은 도둑이나 도난이라는 단어처럼 자산에 손실을 초래할 수 있는 원치 않은 사건의 잠재적인 원인이나 행위자로 정의할 수 있음
- ✓ 금고가 쉽게 찾을 수 없는 곳에 숨겨져 있고 그곳에 비밀번호, 자물쇠 등의 접근통제가 되어 있으면 취약점이 낮은 것으로 볼 수 있음
 - ✓ 취약점은 자산의 잠재적 속성으로서 위협의 이용대상으로 정의되나 보통 정보보호대책의 미비로 정의되기도 함
 - ✓ 위협과 취약점은 서로 관계가 있으며, 두 개념이 서로 맞물렸을 경우 실제적인 위험이 되므로 일반적으로 위협과 취약점을 묶어서 우려사항이라고 표현하는데 이 우려사항은 위의 도둑과 금고의 예처럼 하나의 위험 시나리오라고 할 수 있는 것



위험 분석 개요

2. 위험의 구성요소

2) 정보보호대책

- 정보보호대책이란 위협에 대응하여 자산을 보호하기 위한 관리적, 기술적 대책으로 정의되며, 이러한 대책에는 방화벽, 침입탐지시스템 등의 제품뿐만 아니라 절차, 정책, 교육 등의 모든 통제사항들이 포함

“취약점 보호 및 위협의 발생 자체를 억제”

보호대책 선택

- 조직의 환경과 문화에 맞는 것을 선택하는 것이 중요
- 비용산정 시 구축비용뿐만 아니라 운영에 따른 관리비용도 고려

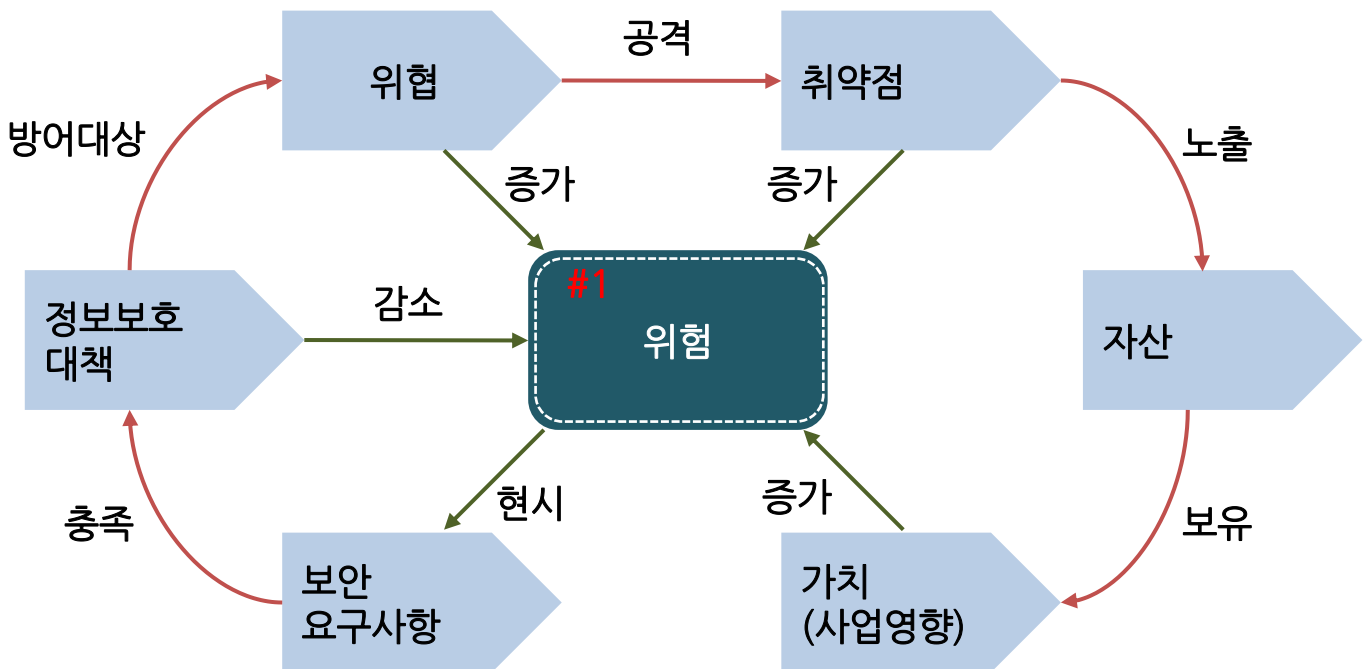
보호대책 선정의 정당화

- 특정 보호대책이 어떤 위협을 어느 정도 제거할 수 있는지 그 효과 정도를 평가하여 보호대책의 구현 및 관리비용과 비교 제시

🔑 위험 분석 개요

3. 위험 구성요소들간의 관계

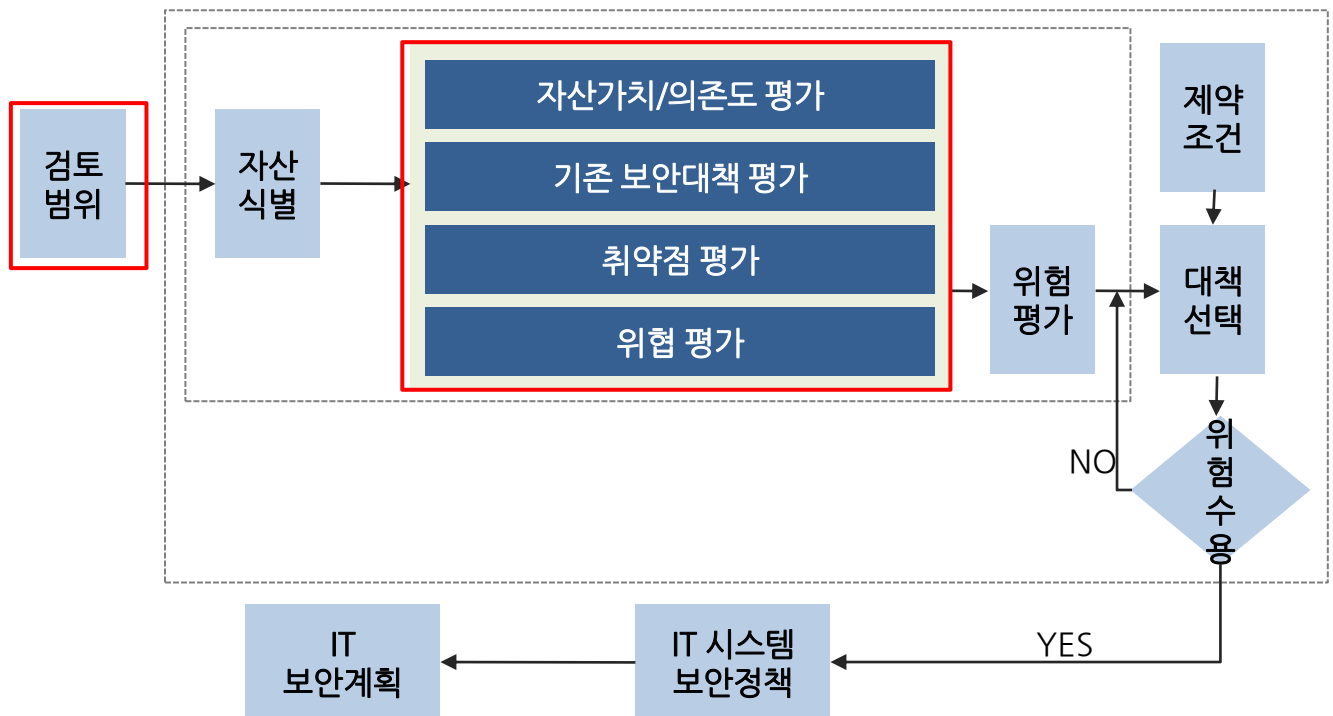
- 위협은 취약점을 공격하여 이용하게 되며 취약점은 자산을 노출시키게 됨
- 자산은 가치를 보유하는데 위협, 취약점, 자산, 가치는 모두 위험을 증가시키게 됨
- 위험을 파악함으로써 보안 요구사항을 파악할 수 있으며, 보안 요구사항을 만족시키는 정보보호대책을 선정하여 구현함으로써 위협을 방어할 수 있고, 정보보호대책은 위협을 방어함으로써 위험을 감소시키게 됨



🔑 위험 분석 개요

4. 위험 분석 절차

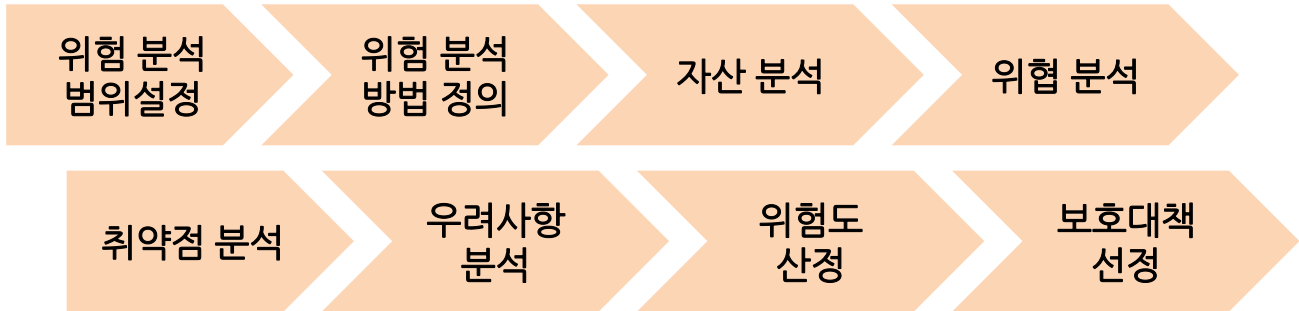
- 위험 분석은 먼저 검토범위를 선정 후 자산 식별을 함
- 자산가치 및 의존도 평가, 기존 보안대책 평가, 취약점 평가, 위협 평가내용을 고려하여 위험을 평가하고 대책을 선택함
- 위험 수용 단계에서 적합하지 않을 경우 다시 위험 평가가 진행되고, 위험이 수용 가능할 경우 IT 시스템 보안정책을 확인하여 IT 보안계획을 세우게 됨





위험 분석 개요

4. 위험 분석 절차



1) 위험 분석 범위 설정

- 업무, 조직, 위치, 자산 및 기술적 특성에 따라 위험 분석 범위를 설정

2) 위험 분석 방법 정의





위험 분석 개요

4. 위험 분석 절차

2) 위험 분석 방법 정의

(1) 계량화 여부에 따른 분석 방법

① 정량적 방법

- 손실크기를 **화폐 단위로 측정** 가능할 때 사용
- 과거자료 접근법, 수학기식 접근법, 확률분포 추정법 등
- 장점 : 비용 효과 분석 및 예산 계획이 용이
- 단점 : 계산이 논리적이거나 수리계산에 많은 시간과 노력 필요하고
정확한 정량화 수치 구하기 어려움

② 정성적 방법

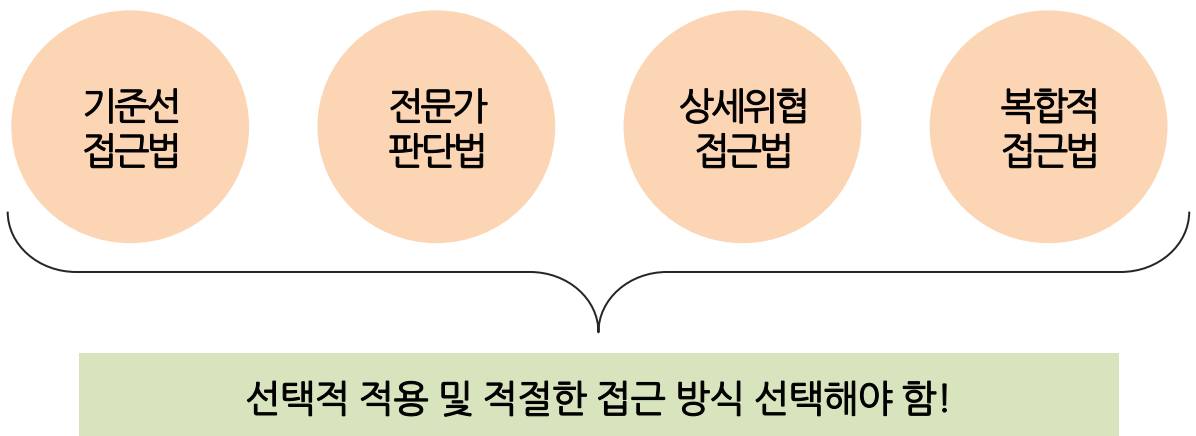
- 손실크기를 측정할 수 없어서 위험을 **구간 및 기술변수**로 표현
- 분석자의 경험 및 지식에 기초 : 델파이법, 시나리오법,
순위결정법 등
- 장점 : 정량화하기 어려운 정보의 평가에 용이하고 분석의
소요시간이 짧음
- 단점 : 주관적 판단의 남용 여지 있으며 비용-효과 분석 어려움

4. 위험 분석 절차

2) 위험 분석 방법 정의

(2) 접근 방식에 따른 분석 방법

- 다음으로 접근 방식에 따른 분석 방법에는 일반적으로 기준선 접근법, 전문가 판단법, 상세위협 접근법, 복합적 접근법이 있으며, 이들 방법 중에서 선택적으로 적용이 가능한데, 위험 분석 및 평가 대상 조직의 보안 요구사항, 전문인력, 기간, 예산 등 가용자원 규모 등을 고려하여 적절한 접근 방식을 선택해야 함





4. 위험 분석 절차

2) 위험 분석 방법 정의

(2) 접근 방식에 따른 분석 방법

① 기준선 접근법

- **보호의 기본수준 선택 및 일련의 보호대책을 선택**
- 시간과 비용이 많이 들지 않고, 모든 조직에서 기본적으로 필요한 보호대책 선택 가능
- 조직 내에 부서별로 적정 보안수준보다도 높게 혹은 낮게 보안통제 적용

② 전문가 판단법

- 전문가의 지식과 경험에 따라 위험 분석
- 작은 조직에서 비용효과적임
- 위험을 제대로 평가하기 어려움
- 보호대책의 선택 및 소요비용을 합리적으로 도출하기 어려움
- 계속 반복되는 보안관리의 보안감사 및 사후관리가 제한



4. 위험 분석 절차

2) 위험 분석 방법 정의

(2) 접근 방식에 따른 분석 방법

③ 상세위협 접근법

- 자산의 가치를 측정하고 자산에 대한 위협의 정도와 취약점을 분석하여 위협의 정도를 결정
- 조직 내에 적절한 보안수준 마련이 가능
- 전문적인 지식과 시간과 노력이 많이 소요

④ 복합적 접근법

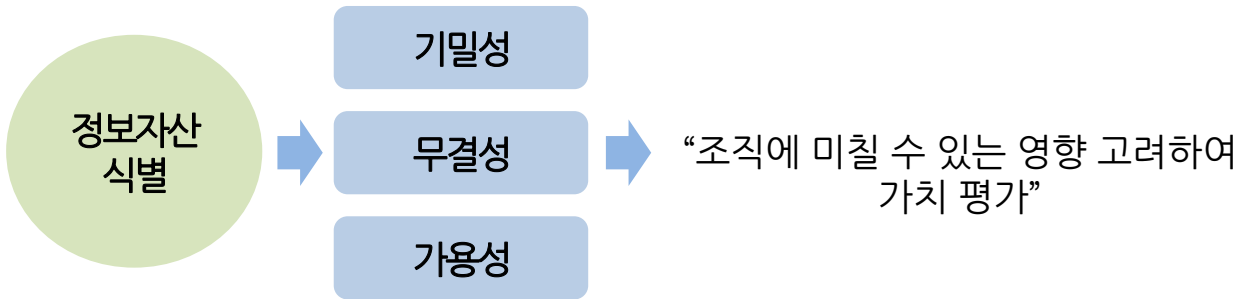
- 조직 활동에 대해 필수적이고 위험이 높은 시스템을 식별
- 보안전략을 빠르게 구축할 수 있고 상대적으로 시간과 노력을 효율적으로 활용 가능
- 두 가지 방법의 적용대상을 명확하게 설정하지 못할 경우 자원의 낭비 발생 가능성이 존재



위험 분석 개요

4. 위험 분석 절차

3) 자산 분석



4) 위협 분석

자산에 대한 위협의 식별 및 발생 가능성의 정도를 인터뷰 또는 실사를 통해 측정

5) 취약점 분석

식별된 위협에 대하여 자산이 어느 정도 취약한가를 인터뷰 또는 실사를 통해 판명

6) 우려사항 분석

데이터 정보와 같이 위협과 취약점의 구분이 어려운 경우,
‘우려사항’이라는 용어 정의로서 이용 가능



위험 분석 개요

4. 위험 분석 절차

7) 위험도 산정

위험도 산정 단계에서는 식별된 자산, 위협 및 취약점을 기준으로 위험도를 산출하고 기존의 보호대책을 파악하는 단계로, 식별된 자산별 위협, 취약점 및 위험도를 정리하여 위험을 평가하게 됨

8) 보호대책 선정

위험도 평가결과를 토대로 해당 위험도를 수용 가능한 위험수준까지 낮추기 위한 보호대책을 선정하는 과정

1. 위협 식별

1) 위협 목록 및 위협 시나리오 작성

- 위협 분석은 자산에 피해를 가할 수 있는 잠재적인 요소인 위협을 파악하고, 위협의 영향 및 발생 가능성 등을 분석하는 과정으로 위협을 산출하는데 있어서 중요한 단계입니다. 따라서 위협을 식별하기 위해서는 위협 목록 및 위협 시나리오를 작성해야 함
- 위협 유형은 이는 각 자산에 대한 위협을 식별할 때 모든 자산에 대해 모든 위협을 식별할 경우 많은 시간과 노력을 필요로 하기 때문에 위협이 영향을 미칠 수 있는 IT 분야의 자산과 취약점과의 관계를 고려하여, 위협을 네트워크, 하드웨어, 소프트웨어, 데이터, 사용자, 환경 등으로 분류하여 파악하고, 위협 식별 시 분류된 위협 목록을 대상으로 각 자산별 식별을 수행해야 함

위협 분석

1. 위협 식별

1) 위협 목록 및 위협 시나리오 작성

위협 조사

위협유형에 따라 현존하거나 알려지지 않은 위협들을 조사하는 단계

[알려진 위협]

- 조직에서 발생되었거나 파악된 위협
- 전산실 장애관리 일지, IT 보안조직에서 대응했던 사고대응 일지 등을 바탕으로 조사 수행

[위협 시나리오]

- 가상의 위협 환경 설정 후 발생 가능한 위협을 유추하여 위협을 찾아내는 방법
- 행위자, 접근경로, 동기, 결과 등의 항목으로 구분하여 실제 발생 가능한 시나리오 작성

위협 분석

1. 위협 식별

1) 위협 목록 및 위협 시나리오 작성

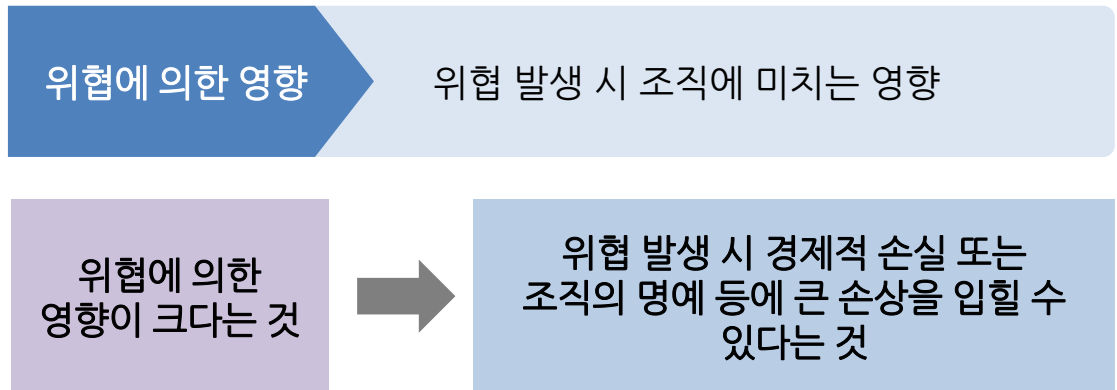
[위협 시나리오]

자산에 대한 행위자	•인간 : 내부자 , 외부자, 제3자 •비인간 : 기술, 환경(사회적 문제), 자연(자연재해)
자산에 접근하는 경로	•네트워크 : 네트워크를 통해서 접근 •물리 : 물리적으로 직접 접근
자산에 접근하는 동기	•우연 : 목적 없이 우연히 접근 •고의 : 어떤 목적을 달성하기 위해 접근
자산에 미치는 결과	•변경 : 자산의 내용이 수정되거나 변경된 상태 •노출 : 자산의 내용이 공개 •손실/파괴 : 자산이 손실되거나 파괴 •방해 : 자산이 다른 영향으로 방해를 받는 경우

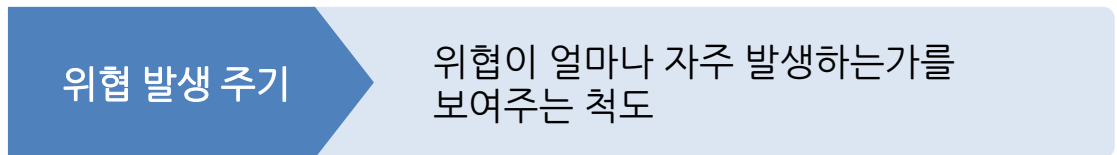
🔑 위협 분석

1. 위협 식별

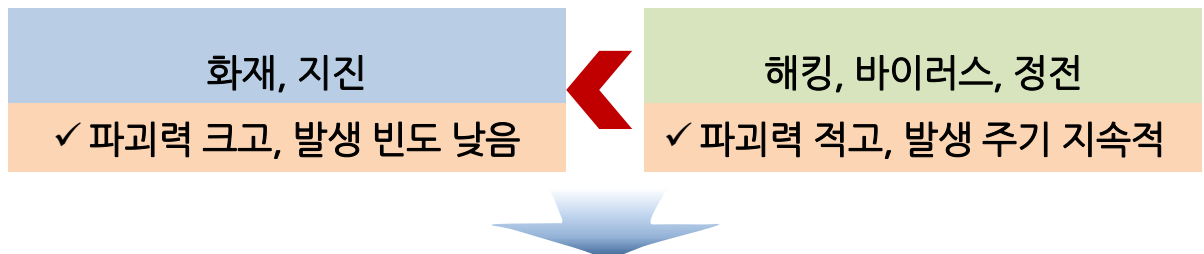
1) 위협 목록 및 위협 시나리오 작성



“각 위협에 대한 영향도를 정확하게 예측 혹은 파악해야 함”



“피해규모가 작은 위협이라도 지속적으로 발생할 경우 그 영향은 매우 큼”



“정확한 위협 평가 및 위협 발생 가능성 유추하여 사용해야 함”

위협 분석

1. 위협 식별

2) 위협 평가 기준 설정

- 위협이 자주 발생 하는가?
- 가끔씩 발생하거나 혹은 거의 발생하지 않는가?



“발생 주기 또는 발생 가능성과
위협 발생 시 미치는 영향을 근거로
위협 평가 기준 설정”

[위협 평가 기준표]

평가	위협에 의한 영향	발생 주기 또는 발생 가능성
낮음(L)	위협으로 인한 손실이 매우 경미	자산의 Life Cycle 동안 거의 발생하지 않음
중간(M)	위협으로 인한 손실이 있으나, 업무에 심각하게 영향을 끼치지 않음	시스템 자산이 Life Cycle 동안 두세 차례 손해를 입을 수 있는 상태 (1년 이내)
높음(H)	위협으로 인한 손실이 크나, 업무의 중단을 초래하지는 않음	시스템의 Life Cycle 동안 다섯 번 이상 발생할 수 있는 상태 (6개월 이내)
매우 높음(VH)	손실이 매우 크고, 업무가 장시간 중단	시스템의 Life Cycle 동안 매우 자주 발생 (3개월 이내)

위협 분석

1. 위협 식별

2) 위협 평가 기준 설정

[위협 평가 매트릭스]

위협 평가
매트릭스

위협의 정도를 평가하는 평가표

위협 영향	L				M				H				VH			
발생 주기	L	M	H	VH	L	M	H	VH	L	M	H	VH	L	M	H	VH
위협 정도	2	3	4	5	3	4	5	6	4	5	6	7	5	6	7	8
위협 등급	1	2	2	3	2	2	3	3	2	3	3	4	3	3	4	4

※ 위협 등급 : 1등급 - 위협 정도 2
 2등급 - 위협 정도 3~4
 3등급 - 위협 정도 5~6
 4등급 - 위협 정도 7~8

2. 위협 평가

위협 평가

대상조직의 자산에 대해 위협의 중요도를 평가하는 과정

“위협 평가 기준표와 위협 평가 매트릭스에 의해 산출하는 방식 사용”

[담당자 면담을 통한 위협 평가]

- 정확도는 다소 떨어질 수 있음
- 정성적인 방식에 의해 위협의 중요도를 정하는 것이 현실적으로 실현 가능

“담당자 면담을 통한 위협 평가 절차”

위협 평가표
작성



위협 평가지
원



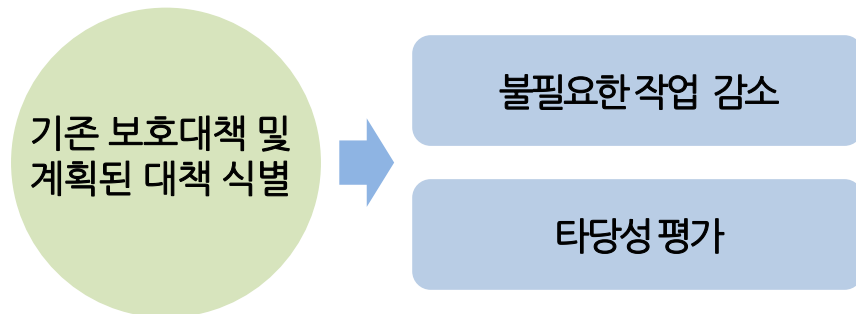
위협 평가
점수 재검토

위협 분석

3. 위협 평가 이후의 과정

1) 기존 보호대책 분석

- 관리적, 물리적, 기술적 취약점에 대한 기존 보호대책 적용사항 분석 수행



2) 위협 산정

- 주요 자산에 대한 위협 수준 평가 및 위협 산정
- 위협 시나리오 작성 및 분석, 자산·위협·취약점 매트릭스 작성



위협 분석

3. 위협 평가 이후의 과정

3) 위협 시나리오

- 자산에 취약점이 존재할 경우 특정 위협에 의해 위협 발생 가능
- 이에 대한 보호대책을 마련해야 한다는 일련의 과정을 정의하는 것



4) 위험도 산정 기준

- 위험도에 대한 명확한 정의 후 정량적 또는 정성적으로 표현

위협		L				M				H				VH			
취약점		L	M	H		L	M	H		L	M	H		L	M	H	
자 산	L	1	2	3	4	2	3	4	5	3	4	5	6	4	5	6	7
	M	2	3	4	5	3	4	5	6	4	5	6	7	5	6	7	8
	H	3	4	5	6	4	5	6	7	5	6	7	8	6	7	8	9
	VH	4	5	6	7	5	6	7	8	6	7	8	9	7	8	9	

5) 위험 평가

- 평가자산에 대한 위험도의 의미 및 위험 관련 평가의견 기재
- 실제 담당자가 이해하고 관리할 수 있도록 관련 정보 제공



핵심요약

1. 위험 분석 개요

- 위험의 정의
: 원하지 않은 사건이 발생하여 손실 또는 부정적인 영향을 미칠 가능성
- 위험의 구성요소 : 자산, 위협, 취약점
- 위험 구성요소들간의 관계
: 위협은 취약점을 공격하여 이용하게 되며, 취약점은 자산을 노출시키고, 자산은 가치를 보유하는데 이러한 위협, 취약점, 자산, 가치는 모두 위험을 증가시킴
- 위험 분석 절차
: 위험 분석 범위 설정 → 위험 분석 방법 정의 → 자산 분석 → 위협 분석
→ 취약점 분석 → 우려사항 분석 → 위험도 산정 → 보호대책의 선정

핵심요약

2. 위협 분석

- 위협 식별

: 위협 식별 시 분류된 위협 목록을 대상으로 각 자산별로 식별 수행

- ✓ 위협목록 및 위협 시나리오 작성

- 위협 조사 : 위협유형에 따라 현존하거나 알려지지 않은 위협들을 조사하는 단계
- 위협 시나리오 : 행위자, 접근경로, 동기, 결과 등의 항목으로 구분하여 실제 발생 가능한 시나리오 작성

- ✓ 위협 평가 기준 설정: 위협 평가 기준표, 위협 평가 매트릭스

- 위협 평가 : 대상조직의 자산에 대해 위협의 중요도를 평가하는 과정

- 위협 평가 이후의 과정

: 기존 보호대책 분석 → 위협 산정 → 위협 시나리오 → 위험도 산정
→ 위협 평가